SECCIÓN 7.7

Riesgos de dependencia excesiva y criterio operativo final

Temas de esta sección:

- Automation bias: aceptar recomendaciones automáticas sin validar impacto
- Alert fatigue: cerrar rápido por volumen sin revisar evidencia
- Pérdida de criterio: copiar outputs de IA o scores sin validar
- Checklist operativo antes de aceptar una recomendación automática o un output de IA
- Caso integrador 1: SOAR recomienda aislar WEB-PAY-01
- Caso integrador 2: IA redacta pero sobreafirma
- Caso integrador 3: score alto, contexto legítimo

7.7 | Riesgos principales de depender demasiado

AUTOMATION BIAS

Aceptar una recomendación automática porque viene de una herramienta, sin validar si el contexto la justifica.

Ejemplo:
Aislar un servidor porque SOAR lo recomienda, sin validar criticidad del activo ni impacto operativo.

⚠ La herramienta no conoce el contexto de negocio.

ALERT FATIGUE

Cerrar rápido por volumen de alertas o repetición, sin revisar si la evidencia cambia.

Ejemplo:
Ignorar PowerShell porque aparece todos los días, sin revisar si el parent process cambió esta vez.

⚠ La repetición no garantiza benigno.

PÉRDIDA DE CRITERIO

Copiar outputs de IA, scores o resúmenes sin validar evidencia real.

Ejemplo:
Escribir 'exfiltración confirmada' porque la IA lo sugirió, sin evidencia técnica de salida de datos.

⚠ La IA no tiene responsabilidad operativa. El analista sí.

7.7 | Decisiones asistidas: checklist operativo

Antes de aceptar cualquier recomendación automática o usar un output de IA:

Antes de aceptar una recomendación automática

- ☐ ¿Qué evidencia sostiene la recomendación?
- ☐ ¿Qué fuente generó la alerta original?
- ☐ ¿Hay otra fuente que confirme o contradiga?
- ☐ ¿Cuál es la criticidad del activo o cuenta?
- ☐ ¿Qué impacto tendría la acción recomendada?
- ☐ ¿El playbook permite ejecutarla?
- ☐ ¿Se necesita aprobación humana?
- ☐ ¿Documenté por qué acepté o rechacé la recomendación?

Antes de usar un output de IA

- ☐ ¿La IA recibió todos los datos relevantes?
- ☐ ¿Puede estar inventando o generalizando?
- ☐ ¿Hay datos sensibles involucrados?
- ☐ ¿El texto diferencia hechos de hipótesis?
- ☐ ¿La conclusión está sostenida por evidencia?
- ☐ ¿Necesito validación humana o aprobación?
- ☐ ¿Lo revisé contra fuentes técnicas reales?
- ☐ ¿Estoy citando el output de IA como evidencia propia?

7.7 | Caso integrador 1: SOAR recomienda aislar WEB-PAY-01

La automatización puede recomendar, pero la acción debe considerar impacto:

```
SOAR recommendation: Isolate host
Host: WEB-PAY-01
Evidence:
- WAF Command Injection (Alert Only)
- w3wp.exe → cmd.exe → whoami
- shell.aspx in /uploads
Business: payment portal active
```

Decisión esperada:

- No aislar sin coordinación con negocio/infra
- Evidencia fuerte + impacto muy alto
- Escalar urgente: IR/apps/infra/negocio
- Preservar evidencia antes de actuar
- Contención específica: WAF rule, bloqueo origen
- Documentar por qué no se ejecuta aislamiento automático

SOAR recomienda aislar: la evidencia técnica justifica la preocupación. Pero WEB-PAY-01 procesa pagos en producción. Aislar sin coordinación puede cortar el servicio. La respuesta correcta es escalar con urgencia y coordinar la contención.

7.7 | Caso integrador 2: IA ayuda a redactar pero sobreafirma

IA puede redactar, pero el analista debe corregir certeza y evidencia:

```
Output IA:
'La cuenta legal.romero fue comprometida
y exfiltró archivos.'

Evidencia real:
- Login desde dispositivo desconocido
- MFA Success
- Regla forwarding externa
- OAuth Read Mail / Read Files
- 1,200 archivos descargados
- Sin confirmación de salida externa
```

- ✔ Actividad compatible con posible compromiso de cuenta
- ✔ No confirmar exfiltración sin evidencia de salida externa
- ✔ Escalar a identidad/IR
- ✔ Preservar regla, OAuth, sesiones y descargas
- ✔ Validar con usuario por canal aprobado

La IA sobreafirmó: dijo 'comprometida' y 'exfiltró' sin evidencia de salida externa confirmada. El analista debe corregir el nivel de certeza antes de enviar. 'Compatible con posible compromiso' es la frase correcta.

7.7 | Caso integrador 3: score alto, contexto legítimo

Un score alto no reemplaza validación de cambio aprobado:

```
Alert: Suspicious PowerShell
Risk Score: 92/100

User: secops.deploy
Host: APP-SRV-02
Parent: software_deploy.exe
Command: install_agent.ps1
Ticket: CHG-2026-3301
Window: Approved
After: no suspicious activity
```

Decisión esperada:

- Validar ticket, ventana, usuario y host en alcance
- Score alto se explica por comportamiento sensible del modelo
- Si todo coincide → cerrar como actividad autorizada
- Documentar por qué se cuestionó el score
- No ajustar regla sin analizar impacto de detección

Score 92/100 porque PowerShell con ExecutionPolicy Bypass dispara el modelo. Pero el ticket CHG-2026-3301 está aprobado, el usuario y host coinciden, sin actividad posterior. Se cierra como autorizado — documentando por qué se ignoró el score.